Enterprise Risk Assessment

NimbusPay

By Zaina Bhurgari

Introduction and Scope

This assessment is based on a fictional fintech company called NimbusPay, designed to simulate a real-world risk environment. Using simulated business context, assets, and vulnerabilities, we built a risk register, identified key threat scenarios, and conducted an overall risk assessment of the organization. Controls were then recommended using the NIST 800-53 framework.

Business Overview

NimbusPay is a B2B SaaS payment platform with approximately 220 employees. It operates primarily in the US and is considered a small-to-mid-sized business. It generates about $30 million in annual revenue. The company offers:

- Payment processing APIs
- Subscription billing
- Financial reporting dashboards

NimbusPay integrates with banks and third-party services to help businesses accept, process, and track payments across the US. It handles sensitive financial and customer data and is working toward SOC 2 certification.

Technology Environment

- Cloud: AWS (EC2 for app servers, S3 for storage/backups, RDS for transaction database)
- Frontend: React web application
- Backend: Node.js APIs
- Integrations: Third-party analytics tools, payment processors, and banking APIs
- Mobile Access: Limited

Executive Summary

This assessment evaluates NimbusPay's security, operational, and business risks, and offers mitigation strategies aligned with NIST 800-53. Key focus areas include operational processes (such as onboarding), incident response, third-party dependencies, access management, and software security.

NimbusPay has a moderate-to-high risk posture. The most significant gaps are:

- No documented third-party risk management program — this creates legal and compliance exposure if vendors have weak security or informal security.
- Incident response is documented but not practiced consistently. If a cyberattack occurs, the response will be ineffective, leading to data loss, repeated incidents, downtime, and reputational damage. Remediation costs would be $3.5 million approximately.
- Insufficient centralized logging and monitoring — Limits visibility into potential threats and delays detection.
- Weak user access management — increases the risk of data breaches, internal incidents and ransomware.
- Inconsistent vulnerability management — leaves software and, in turn, systems and servers exposed to hackers and malware, risking stolen PII or payment data.
- Lack of testing backups regularly – Creates an inability to perform adequate restoration for lost data in the event of a disaster event.

Top Recommendations

- Build a formal third-party risk management program.
- Implement and test the incident response process regularly based on company policy
- Implement centralized logging (SIEM).
- Improve and regularly review access management controls. Consider automated tools such as SailPoint.
- Implement a repeatable process for remediating known software vulnerabilities based on criticality and company policy.
- Test backups at least annually, according to policy.

Addressing these risks will strengthen NimbusPay's security posture, build customer trust, and reduce financial and legal exposure. Reducing these risks will also lead to overall operational efficiency, allow for increased customer acquisition, as well as accelerate progress toward SOC 2 certification.

Methodology

This assessment uses a combined asset-based, threat-based, and vulnerability-based approach. This was chosen because:

- NimbusPay is a fast-growing startup that needs strong protection of assets against cyber threats. This is because hackers will be more likely to target them.
- As a service integrating with banks, protecting data and up time is critical.
- The AWS standard environment introduces specific vulnerabilities around application servers, storage, backups, and databases. Such vulnerabilities must be remediated.
- Third-party integrations and partnerships add additional risk surface that must be considered.

It is also assumed that executive management is supportive of GRC (governance, risk, and compliance) efforts.

Asset Identification

The following key assets and processes were identified and used to build threat scenarios as well as the risk register:

- Sensitive Data: Customer PII, payment data, transaction history, financial reports
- Systems and Infrastructure: Production AWS environment, CI/CD pipeline, source code repositories, internal admin dashboard
- Access and Identity: Employee credentials, privileged admin accounts, API keys and tokens
- Third-party Dependencies: Payment processors, cloud provider, SaaS tools (e.g., Slack, Jira)
- Business-critical Processes: Payment processing, customer onboarding, financial reporting, incident response

---

Information Security Threat Scenarios

- S3 misconfiguration: An employee accidentally sets an S3 bucket to public, exposing sensitive data and increasing likelihood and impact of a breach. This will lead to reputational damage and legal complications.
- Missing encryption: An employee forgets to enable server-side encryption leaving data vulnerable to credential-based malware attacks, potentially resulting in ransomware or unauthorized account actions. This will create organization-wide operational disruption.
- Ransomware via admin dashboard: Attackers gain admin access due to lack of MFA and then they encrypt or manipulate customer PII and payment data. This will result in financial costs to retrieve the information.
- CI/CD pipeline compromise: Hackers exploit informal security practices to access the pipeline and deploy malicious updates. This will cause damage to the software and operational disruption.
- Credential sharing via Slack: Employees share GitHub credentials over unencrypted channels. An attacker intercepts them, gaining access to source code and history. They then manipulate the data causing confusion and reduced productivity.
- Weak incident response: Inadequate staffing, unclear roles, and untested processes by the IR team will lead to delayed detection, ineffective response, and repeated incidents. This will result in data loss, damage to systems or servers as well as customer distrust.
- Unencrypted credentials: Hackers utilize stolen employee/admin credentials or API keys to act on behalf of legitimate users and take malicious actions. This will harm information systems, data, and servers.
- Access not revoked: Temporary elevated access for an employee that is never removed creates insider threat. The employee will be able to manipulate data or perform unauthorized actions resulting in damage to information systems or servers depending on what type of malicious actions are taken.
- Third-party security gaps: If payment processors or SaaS tools lack compliance certifications or security programs, NimbusPay is exposed to data leaks, service disruptions, or dependency-based failures. This will lead to legal issues and will cause operational disruption if third party risks materialize.

- No vendor risk program: NimbusPay onboards vendors without vetting their security policies and procedures. This can lead to third-party-introduced breaches, penalties, and incidents causing legal complications and reputational damage.

Legal, Financial, and Operational Threat Scenarios

- Fraudulent onboarding: A small company submits fake identity or business documents. This will cause NimbusPay to be liable for not verifying them. This will lead to legal complications.
- Non-compliant onboarding: NimbusPay fails to follow regulatory requirements during onboarding which then results in legal penalties. Being liable or uncompliant could impact the organization's ability to operate.
- Inaccurate financial reporting: Errors in financial reporting by the finance department skew budget decisions, slow operations, and create legal risk. This impacts productivity and it will lead to legal complications.

Risk Register

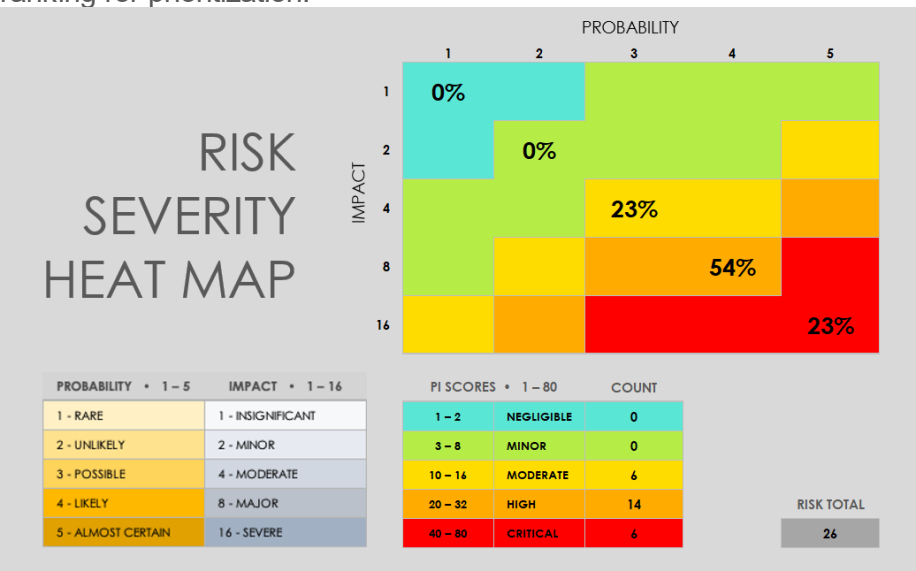
The risk register documenting all identified risks is available at the link below. It includes granular risks for each category.

https://docs.google.com/spreadsheets/d/1xxOA6ISNeeAduixoKe6SWIJwP-tUwMUBh-xsbLyKlyc/edit?usp=sharing

---

Risk Heat Map

A visual risk heat map was created to show how many risks were identified as well as their ranking for prioritization.



Control Recommendations

Since NimbusPay primarily operates in the USA, controls were drawn from the NIST 800-53 framework. It covers controls for organizational, physical, technological, and people categories, making it comprehensive enough to address all identified risks.

Key recommendations for such categories include:

- Access control: Deploy AWS CloudTrail logs into a centralized SIEM with automated alerting. Define who reviews logs and how often.
- Third-party risk: Standardize collection of compliance certifications and audit reports from all vendors.
- Customer onboarding: Standardize the onboarding process and ensure monitoring is in place to keep NimbusPay and its customers legally compliant.

SOC 2 Pathway

NimbusPay should leverage AWS's built-in monitoring and security foundations to work toward SOC 2 certification. The Trust Services Criteria (TSC) should guide this effort. The required "Security" category means NimbusPay must assess:

- Control environment and risk assessment
- Logical and physical access controls
- System operations and change management
- Monitoring controls and risk mitigation

After completing this risk assessment and implementing risk treatments, NimbusPay can identify remaining gaps and work toward full SOC 2 readiness.

Control Mapping to NIST 800-53

The table below shows each control area, what needs to be implemented, and the relevant NIST 800-53 reference. This includes not only information security risks, but also onboarding risks, third party, software and financial reporting risks.

Control Area	Key Actions	NIST 800-53 Reference
Access Control	Review access controls, config changes, code integrity validation	AC-2, AC-3, AC-6, CM-3, SI-7
Logging	Deploy SIEM, AWS CloudTrail, human log reviews	AU-2, AU-3, AU-6, AU-12, SI-4
Incident Response	Tabletop exercises, logging trails, SIEM, root cause analysis, threat identification and modeling, defined roles	IR-2, IR-4, IR-5, IR-6, IR-8
Software Development	Change management, critical change reviews, security at all stages	SA-11, SA-15, CM-3, SA-8, SI-2
Supplier Relationships	Formal vendor risk program, agreed-upon security requirements, audits	SR-3, SA-9, SR-5, SR-6, SA-4

Control Area	Key Actions	NIST 800-53 Reference
Security Training	Formal monthly class or webinar for all employees	AT-2, AT-3, AT-4, PL-4
Backups	Test backups regularly, implement scheduled backup process	CP-9, CP-10, CP-2
Malware	Social engineering training, encryption, antivirus, firewalls, IDS, backups	SI-3, SI-4, SC-7, SC-28, CP-9, AT-2
Supplier Agreements	Formal third-party review and audit, ensure legal/regulatory compliance	SR-3, SR-5, SA-9, SA-4, SR-6
Threat Management	Threat modeling, SIEM, logging, IDS, monitor threat landscape	RA-3, SI-4, AU-6, CA-7, RA-5
Asset Handling	Update asset handling procedures, enforce due process for breaches	CM-8, MP-2, MP-6, IR-6, MP-4
Access Reviews	Update full access review process	AC-2, AC-6, IA-4, AC-5, IA-5
Public Networks	Clear messaging/tool use policies, enforce security on public networks	SC-7, SC-8, SC-13, AC-17, SC-20
Encryption	Review encryption for data at rest and in motion	SC-28, SC-8, SC-13, SC-12
Disaster Recovery	Standardized reporting and documentation, periodic DR reviews	CP-2, CP-10, IR-8, CP-4, CP-9

Risk Treatment Plan and Priority

Priority	Risk IDs	Timeline
Critical	1, 2, 7, 8, 11, 12	Immediate (0–5 months)
High	3, 4, 5, 6, 9, 10, 13, 14, 15, 16, 18, 19, 20, 24	3–9 months
Moderate	17, 21, 22, 23, 25, 26	6–12 months (monitor)

Justification for Risk Rating

Likelihood was scored on a 1–5 scale. Impact was scored on a 1–16 scale (1 = insignificant, 16 = severe).

- Critical risks (6 total): These have the highest potential damage — for example, attackers gaining access to an admin dashboard or main code repository. The impact is organization wide.
- High risks (14 total): These include third-party and legal/regulatory risks with significant organizational impact.

- Moderate risks (6 total): These are lower-likelihood or lower-impact risks, such as onboarding issues and some software development gaps. NimbusPay already has some controls in place for this area but should continue to monitor and improve when possible.

Address critical risks first using a “mitigate, avoid, or transfer” strategy. Once those controls are in place, move on to high risks, then moderate ones.

Conclusion

This assessment identified the key information security, operational, and business risks facing NimbusPay. By implementing the recommended NIST 800-53 aligned controls, NimbusPay will significantly reduce its risk exposure, build stronger security posture, and earn greater customer trust. It will also help move the organization closer to SOC 2 certification. Ultimately, it will improve operational efficiency, reduce the likelihood of costly incidents, legal penalties, and reputational damage.